

 Join us for the **Bitwarden Product Deep Dive**  August 12, 2026, or learn at your own pace with short **video playlists**. 

Bitwarden Statement on Checkmarx Supply Chain Incident

 **Adam Eckerle** Bitwarden Employee

Apr 23

The Bitwarden security team identified and contained a malicious package that was briefly distributed through the npm delivery path for @bitwarden/cli@2026.4.0 between 5:57 PM and 7:30 PM (ET) on April 22, 2026, in connection with a broader Checkmarx supply chain incident.

Was I affected?

If you use the Bitwarden command line interface and deploy using NPM, and downloaded the CLI between 5:57p ET and 7:30p ET on April 22, 2026, you may be affected. See remediation steps below.

If you do not use the Bitwarden command line interface you were not affected.

The investigation has currently found no evidence that end user vault data was accessed or at risk, or that production data or production systems were compromised.

What happened?

The investigation has currently found no evidence that end user vault data was accessed or at risk, or that production data or production systems were compromised. Once the issue was detected, compromised access was revoked, the malicious npm release was deprecated, and remediation steps were initiated immediately.

The issue affected the npm distribution mechanism for the CLI during that limited window, not the integrity of the legitimate Bitwarden CLI codebase or stored vault data.

Users who did not download the package from npm during that window were not affected. Bitwarden has completed a review of internal environments, release paths, and related systems, and no additional impacted products or environments have been identified at this time. **CVE-2026-42994** for Bitwarden CLI version 2026.4.0 has been issued in connection with this incident.

[Skip to main content](#) **What users do?**

Only users who installed Bitwarden CLI 2026.4.0 via NPM during the affected window are impacted. If you are an affected user, Bitwarden recommends the following actions

1. Immediately uninstall Bitwarden CLI 2026.4.0 via npm
 - `npm uninstall -g @bitwarden/cli`
2. Clear the npm cache
 - `npm cache clean --force`
3. Temporarily disable npm install scripts during cleanup as a precaution
 - `npm config set ignore-scripts true`
4. Review the additional indicators and cleanup steps outlined by JFrog [here](#)
5. Rotate any secrets that may have been exposed on the affected system or stored in environment variables including API tokens and SSH keys (examples listed [here](#) & [here](#))
6. Review GitHub activity, CI workflows, and related credentials for unauthorized access or changes
7. Install [Bitwarden CLI 2026.4.1](#)

Bitwarden is in the process of completing a full review and will implement mitigation to prevent such attacks in the future.

🔗 [@bitwarden/cli:2026.4.0 infected with malware?](#)

[Skip to main content](#)

[Skip to main content](#)

[Skip to main content](#)

[Skip to main content](#)

[Skip to main content](#)

[Skip to main content](#)

